

**FIRST BANK NIGERIA
SOC INCIDENT TRAINING REPORT**

INVESTIGATION: SQL Injection, Lateral Movement, Process Execution and Fraudulent Transfers

**INCIDENT WINDOW: 20 February 2026,
overnight into 21 February 2026**

**ENVIRONMENT: Kali Linux / Docker / Splunk /
Python analysis workflow**

STUDENT NAME: EKENE MICAEL IKENGA

STUDENT NUMBER: 1001

DATE: 15TH AUGUST, 2026.

**FIRSTBANK NIGERIA
CONFIDENTIAL INCIDENT RESPONSE
REPORT**

**Online Banking System Compromise
20–21 February 2026**

**Prepared for the Executive Committee and
Board Risk Committee**

SOC Incident Response Training Exercise

Confidentiality / Data Notice

This report documents an authorized cybersecurity training exercise. The project brief states that all IP addresses, account numbers, transaction amounts, hostnames, log entries and vulnerability findings are synthetic and do not represent real customers, employees or systems.

TABLE OF CONTENTS

1. Executive Summary/ Customer Impact	4
2. Scope, Environment and Methodology/ Task 1.1 (Identify the Section)..	5
3. Task 1.2 (Trace the Lateral Movement).....	6
4. Task 1.3 (Find the Transfer Script Execution).....	7
5. Task 1.4 (Isolate the Fraudulent Transfer Window).....	8
6. Task 1.5 (Full Attack Timeline).....	9
7. Phase 2: Python Analysis and Evidence Preparation.....	10
8. Technical Remediation Recommendations.....	12
9. Conclusion:.....	15
Appendix A.Complete Nessus Vulnerability Findings Full list of vulnerabilities identified in the pre-incident Nessus scan, by host, in descending order of calculated host riskscore	16–17
Appendix B.Confirmed Attack Timeline.....	18
Appendix Evidence. Screenshot	19
Overall Summary	20-21

EXECUTIVE SUMMARY:

The FirstBank Nigeria SOC project simulated an overnight banking security incident in which automated fraud detection identified unusually large wire transfers. The investigation was designed to answer four questions: how the attacker entered the environment, how the attacker moved internally, what the impact was, and what immediate response actions were required. The project brief identifies Apache web access logs, core banking transaction logs, Windows authentication logs, a Nessus scan and a scenario manifest as the available evidence sources.

The evidence recovered during the investigation shows a coherent attack chain. Repeated web requests from 45.195.195.51 used a sqlmap/1.7.8 user-agent and repeatedly targeted the banking login endpoint. The successful request returned HTTP 200, indicating that the attacker progressed from failed login attempts to successful access.

Windows evidence then links the activity to the service account svc_report. The account received privileged access, established a network logon from the web server, accessed the transaction server, and later created processes on that server. A Python process was launched with bulk_transfer.py and the batch file overnight_batch_20260220.csv.

Finally, the transaction log shows five fraudulent transfers initiated by svc_report. The five transfers total NGN13,094,902.94, occurring between 23:41:52 on 20 February and 00:31:36 on 21 February 2026.

These findings connect the initial web compromise to internal movement, automated process execution and financial impact.

CUSTOMER IMPACT

Five customer accounts were directly affected: **NG76183305, NG98016294, NG92252632, NG35171490 and NG77374324**. The five fraudulent transactions total NGN 13,094,903.00. The first occurred at 23:41:52 on 20 February 2026 and the last at 00:31:36 on 21 February 2026. Customer consequences include direct financial loss pending recovery or reimbursement and potential exposure of account information.

Key findings at a glance

Attacker source IP	45.195.195.51
Automated tool	sqlmap/1.7.8
Compromised service account	svc_report
Web server	WEBSVR01
Transaction server	TXNSVR04
Transfer script	C:\Scripts\bulk_transfer.py
Batch file	overnight_batch_20260220.csv
Fraudulent transfers	5
Total financial impact	NGN 13,094,902.94

Scope, Environment and Methodology:

The project was performed as a controlled SOC training exercise. The supplied project brief requires analysts to use Splunk Search Processing Language (SPL) across three primary log sources and to capture screenshots showing each query and its results. The same brief specifies Python 3.10+ for Phase 2 analysis and instructs the analyst to export the combined timeline as splunk_export.csv for Python processing.

Operating environment	Kali Linux
Container platform	Docker/Docker compose
SIEM	Splunk Enterprise
Analysis language	Python 3.10+
Web evidence	Apache access log / access_combined
Authentication evidence	Windows Security Event Log / windows_auth_training
Financial evidence	Core banking transaction log / banking_transaction

Methodology

- Validate that the banking SOC index contains the expected log sourcetypes.
- Use web-access evidence to identify the initial SQL injection activity and successful login.
- Correlate Windows authentication events with the attacker source and service account.
- Use EventCode 4688 process-creation evidence to identify the transfer automation.
- Filter banking transactions by the compromised service account to isolate fraudulent activity.
- Reconstruct the incident chronologically across web, Windows and transaction evidence.
- Export the resulting timeline to CSV as the bridge into the Python analysis phase.

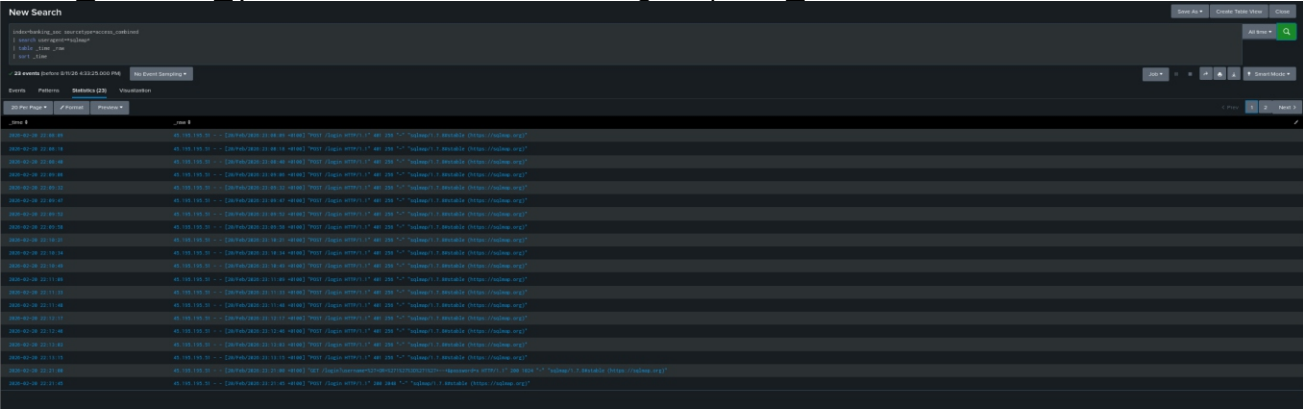
3. Task 1.1 (Identify the SQL Injection)

Objective:

The first investigation step was to identify the attacker's source IP, the automated tool's user-agent, the first successful login, and the request containing a visible SQL-injection payload.

SPL query used:

index=banking_soc sourcetype=access_combined | search uri="/login" OR useragent=sqlmap | table time, src ip, method, status, uri, useragent | sort time



Findings

Source IP	45.195.195.5
User-A	sqlmap/1.7.8
Successful login	20 February 2026 at approximately 23:21:38 +0100, HTTP 200
Target	/login

Attack Pattern	Repeated POST /login requests followed by a successful request containing a visible injection-style parameter
----------------	---

Assessment

The repeated requests, distinctive sqlmap user-agent and transition from HTTP 401 failures to HTTP 200 success provide strong evidence that the web-facing login endpoint was the initial access point. The source address 45.195.195.51 is subsequently visible in the Windows evidence as the origin associated with the compromised service account activity.

Task 1.2 (Trace the Lateral Movement)

Objective

The second step correlated Windows authentication events to determine which service account was hijacked, where the movement originated and where the attacker pivoted.

SPL query used

index=banking_soc sourcetype=windows_auth_training | where EventCode IN ("4624","4648","4672","5140") | table _time, EventCode, AccountName, SourceIP, WorkstationName, TargetServerName | sort _time

_time	EventCode	AccountName	SourceIP	WorkstationName	TargetServerName
2020-02-28 23:25:34	4648	svc_report	45.195.195.51	WEBSVR01	WEBSVR01
2020-02-28 23:25:37	4672	svc_report		WEBSVR01	
2020-02-28 23:28:23	4624	svc_report	18.18.1.45	WEBSVR01	TXNSVR04
2020-02-28 23:28:38	5140	svc_report	18.18.1.45	TXNSVR04	
2020-02-28 23:32:01	4648	svc_report			
2020-02-28 23:32:09	4648	svc_report			
2020-02-21 00:33:01	4648	svc_report			
2020-02-21 00:34:22	4634	svc_report		TXNSVR04	

Findings

Hijacked account	svc_report
Originating host	WEBSVR01
Source IP	45.195.195.51 / web-server-side activity
Pivot target	TXNSVR04
Relevant Event IDs	4648, 4672, 4624, 5140

Interpretation

Event 4648 indicates use of explicit credentials; Event 4672 indicates special privileges; Event 4624 records a successful network logon when the logon type is 3; and Event 5140 records network-share access. In the captured evidence, svc_report appears first in the explicit-credential and privilege events and then in the network logon from the web server to the transaction server. This establishes the lateral-movement stage of the attack

Task 1.3 (Find the Transfer Script Execution)

Objective

After the internal pivot, the investigation searched Windows EventCode 4688 to identify newly created processes, their command lines and the account responsible for execution.

SPL query used

index=banking_soc sourcetype=windows_auth_training EventCode=4688 | table _time, AccountName, NewProcessName, CommandLine, HostName | sort _time

_time	AccountName	NewProcessName	CommandLine	HostName	_raw
2025-02-28 23:32:01	svc_report	C:\Windows\System32\cmd.exe		TXNSVR04	2025-02-28 23:32:01 EventCode=4688 AccountName=svc_report NewProcessName=C:\Windows\System32\cmd.exe ParentProcess=services.exe HostName=TXNSVR04 Status=Success
2025-02-28 23:32:09	svc_report	C:\Python310\python.exe	python.exe	TXNSVR04	2025-02-28 23:32:09 EventCode=4688 AccountName=svc_report NewProcessName=C:\Python310\python.exe CommandLine=python.exe C:\Scripts\bulk_transfer.py --batch overnight_batch_20260220.csv --execute ParentProcess=cmd.exe HostName=TXNSVR04 Status=Success

Supporting result view

_time	AccountName	NewProcessName	CommandLine	HostName
2025-02-28 23:32:01	svc_report	C:\Windows\System32\cmd.exe		TXNSVR04
2025-02-28 23:32:09	svc_report	C:\Python310\python.exe	python.exe	TXNSVR04

Findings

Account	svc_report
Host	TXNSVR04
Process	C:\Python310\python.exe
Full command	python.exe C:\Scripts\bulk_transfer.py --batch overnight_batch_20260220.csv
EventCode 4688	Windows process creation event
Batch file	overnight_batch_20260220.csv

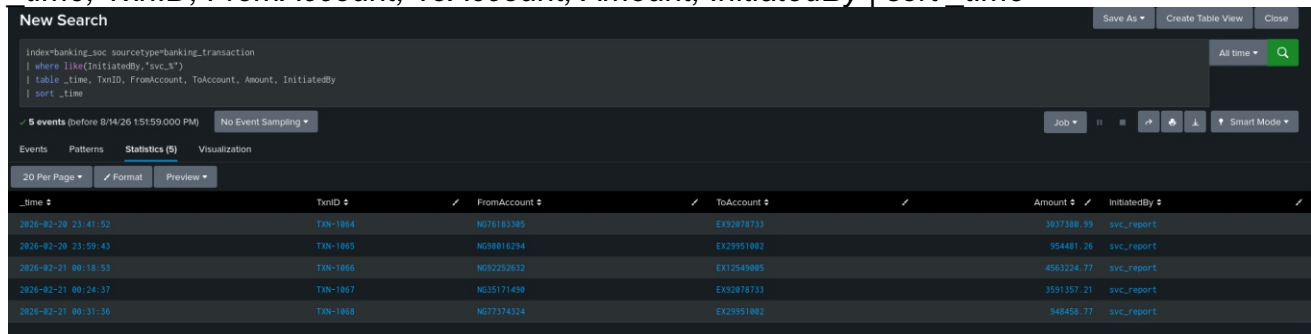
Task 1.4 (Isolate the Fraudulent Transfer Window)

Objective

The transaction log was filtered for InitiatedBy values beginning with svc_. The project brief explains that legitimate transactions are associated with named human users, while the fraudulent transfers in this scenario were initiated by the hijacked service account.

SPL query used

index=banking_soc sourcetype=banking_transaction | where like(InitiatedBy,"svc_%") | table _time, TxnID, FromAccount, ToAccount, Amount, InitiatedBy | sort _time



The screenshot shows a Splunk search interface with the following query: `index=banking_soc sourcetype=banking_transaction | where like(InitiatedBy,"svc_%") | table _time, TxnID, FromAccount, ToAccount, Amount, InitiatedBy | sort _time`. The results table displays 5 events, all initiated by 'svc_report'.

_time	TxnID	FromAccount	ToAccount	Amount	InitiatedBy
2026-02-20 23:41:52	TXN-1064	NGN76183305	XX92078733	3037380.93	svc_report
2026-02-20 23:59:43	TXN-1065	NG98016294	XX29951002	954481.26	svc_report
2026-02-21 00:18:53	TXN-1066	NG92252632	XX12549005	4563224.77	svc_report
2026-02-21 00:24:37	TXN-1067	NG35171490	XX92078733	3591357.21	svc_report
2026-02-21 00:31:36	TXN-1068	NG77374324	XX29951002	948458.77	svc_report

Fraudulent Transactions

TxnID	FromAccount	ToAccount	Amount (NGN)	Time
TXN-1064	NGN76183305	XX92078733	3037380.93	11:41:52 PM
TXN-1065	NG98016294	XX29951002	954481.26	23:59:43
TXN-1066	NG92252632	XX12549005	4563224.77	00:18:53
TXN-1067	NG35171490	XX92078733	3591357.21	12:24:37 AM
TXN-1068	NG77374324	XX29951002	948458.77	12:31:36 AM

Nmber of fradilent transfer	5
Total amount	NGN 13,094,902.94
First transfer	20 February 2026, 23:41:52
Last transfer	21 February 2026, 00:31:36
Receiving accounts	XX92078733, XX29951002 and XX12549005

Task 1.5 (Full Attack Timeline)

The complete attack story emerges when the three evidence sources are placed on one chronological timeline.

The sequence below is based on the timestamps visible in the supplied Splunk screenshots.

Time	Evidence	Observed activity
20 Feb, 22:08:09 onward	Web access	Repeated HTTP 401 login attempts from 45.195.195.51 using sqlmap/1.7.8.
20 Feb, 23:21:38	Web access	Successful HTTP 200 login request; initial web compromise established.
20 Feb, 23:25:34	Windows	svc_report explicit-credential activity (EventCode 4648).
20 Feb, 23:25:37	Windows	svc_report receives special privileges (EventCode 4672).
20 Feb, 23:28:23	Windows	Successful network logon to TXNSVR04 (EventCode 4624).
20 Feb, 23:28:38	Windows	Network share access on the transaction server (EventCode 5140).
20 Feb, 23:32:01	Windows	Windows cmd.exe process created under svc_report.
20 Feb, 23:32:09	Windows	Python executes bulk_transfer.py with overnight_batch_20260220.csv.
20 Feb, 23:41:52	Banking	First fraudulent transfer, TXN-1064.
20 Feb, 23:59:43	Banking	Fraudulent transfer, TXN-1065.
21 Feb, 00:18:53	Banking	Fraudulent transfer, TXN-1066.
21 Feb, 00:24:37	Banking	Fraudulent transfer, TXN-1067.
21 Feb, 00:31:36	Banking	Last fraudulent transfer, TXN-1068.

Attack Chain Conclusion:

Initial access → service-account compromise → privilege assignment → lateral movement → transfer-script execution → fraudulent transfers. The evidence sources reinforce one another: the web source identifies the origin, Windows logs identify the account and movement, and the banking log identifies the resulting financial transactions.

Phase 2: Python Analysis and Evidence Preparation

The project brief defines Python as the analysis tool for Phase 2. At the end of Task 1.5, the combined Splunk results are exported as `splunk_export.csv` and copied into the student directory beside `analysis.py`. This creates a reproducible hand-off from SIEM investigation to programmatic analysis. The supplied project material available for this report documents the export step but does not include the complete final Python output. For that reason, this section records the verified Phase 2 workflow without inventing additional Python findings.

Expected analysis workflow

- Read `splunk_export.csv` using Python.
- Parse timestamps and preserve the event source fields.
- Group or filter events by event label, account and source.
- Identify service-account activity and fraudulent transaction records.
- Calculate or verify totals such as transaction count and total NGN amount.
- Produce a concise analytical summary suitable for the final written report.

Evidence hand-off

The project instructions direct the analyst to export the Task 1.5 results as CSV and save them as `splunk_export.csv` in the student/ directory. The Python stage therefore works from the same correlated evidence used to construct the attack timeline.

Python relevance to the investigation

Python adds repeatability and reduces manual calculation when working with exported SOC data. In this investigation, the transaction total reported in the Splunk evidence was independently summed from the five displayed transfer amounts, producing **NGN 13,094,902.94**.

Impact Assessment and Immediate Response

Impact assessment The confirmed synthetic impact consists of five fraudulent wire transfers totaling **NGN 13,094,902.94**. The activity affected multiple source accounts and directed funds to attacker-controlled receiving accounts. The use of an internal service account and an automated Python transfer script indicates that the compromise progressed beyond the public-facing web application into the transaction-processing environment.

Immediate containment recommendations

- Disable or rotate `svc_report` credentials and review all systems where the account is authorized.
- Contain **WEBSVR01** and **TXNSVR04** for forensic preservation and to prevent continued attacker access.
- Block the identified attacker source **45.195.195.51** at appropriate perimeter controls.
- Stop or quarantine the transfer automation associated with `bulk_transfer.py` and the overnight batch file.
- Review and hold suspicious transactions connected to the identified receiving accounts.
- Preserve logs and evidence from web, Windows and transaction systems before making destructive changes.
- Review privileged service accounts and enforce least privilege, strong authentication and monitored service-account use.
- Investigate the initial SQL-injection weakness and remediate the underlying application vulnerability before returning the affected service to normal operation.
- Detection improvements
- Alert on repeated SQL-injection signatures and automated-tool user-agents.
- Correlate web-server compromise with service-account authentication within a short time window.

- Alert when a service account performs interactive or unusual network logons.
- Monitor process creation for Python execution on transaction-processing servers.
- Create transaction alerts for abnormal service-account-initiated transfers.

Under Phase 3 Full Pyyton Analysis:

I made a research/Analysis using the SQL Query provided.

Customer Impact

This section sets out, in terms relevant to customers and to the bank's duty of care toward them, which accounts were affected, how much value was exposed, and what FirstBank Nigeria owes those customers as a result.

Accounts Affected

Investigation of the transaction logs during the attack window identified five customer accounts from which funds were fraudulently transferred. These accounts are listed below for internal reference; customer-facing communications should follow the bank's standard data-handling procedures for naming affected individuals.

Financial Exposure

Metric	Value
Number of fraudulent transfers	5
Total value transferred	NGN 13,094,903.00
Average transfer value	NGN 2,618,980.60
Attack window	20 February 2026, 23:41:52 UTC – 21 February 2026, 00:31:36 UTC
Receiving parties	External accounts controlled by the attacker (not FirstBank customers)

Consequences for Affected Customers

- Direct loss of funds from the five identified accounts pending FirstBank's fraud reimbursement process.
- Temporary inconvenience if account access is suspended or credentials are reset as part of containment.
- Potential downstream exposure if any personal or account data was viewed by the attacker during the period of administrative access (the attacker's web requests included access to account-listing and user-listing functions, which may have exposed data beyond the five debited accounts).
- A statutory right, under Nigerian data-protection law, to be notified if their personal data was affected by the breach (see Section 3).

Recommended Customer-Facing Actions

- Make the five affected customers whole by reversing the fraudulent debits, consistent with standard fraud-liability practice for unauthorised electronic transfers.
- Proactively contact affected customers rather than waiting for them to notice discrepancies, and offer dedicated support through the bank's fraud response team.
- Force a password and credential reset for the affected accounts, and offer it as a precaution to any customer whose data may have been exposed via the admin/accounts and admin/users pages access during the attack.

- Monitor the five affected accounts, and any accounts sharing the receiving-account details, for further suspicious activity.

Technical Remediation Recommendations

The Nessus vulnerability scan performed prior to the incident had already identified the flaw that enabled the attacker's initial entry, along with a substantial number of other unpatched, high-severity vulnerabilities across FirstBank's scanned environment. This section sets out the remediation plan, prioritised by the role each finding played in this incident and by overall risk score

Immediate Actions (0–24 hours)

- Disable and rotate credentials for the svc_report service account; audit every system where it has been granted access, and remove standing privileges it does not require for its legitimate reporting function.
- Isolate the entry-point host (10.10.1.45) and the transaction server (10.10.9.20 (TXNSVR04)) from the network for forensic imaging before any further changes are made to either system.
- Block 45.195.195.51 at the perimeter firewall and web application firewall (WAF), and review outbound traffic logs for any other connections from this address.
- Freeze or reverse the five fraudulent transfers identified in Section 2, and place a temporary hold on the external receiving accounts pending law-enforcement engagement.
- Preserve all web, Windows authentication, and transaction logs relevant to the incident window before any log-rotation policy can overwrite them.

Root-Cause Remediation:

The Entry-Point Vulnerability The Nessus scan identified the exact vulnerability the attacker exploited: a SQL injection flaw in the login form on host 10.10.1.45 (CVE-2023-23752, CVSS 9.8, Critical), on port 443. This finding was present in the pre-incident scan, meaning it was a known, documented weakness at the time of the attack.

CVE	CVSS	Finding	Required Action
CVE-2023-23752	9.8 Critical	Login form SQL injection	Use parameterised queries / prepared statements; deploy a Web Application Firewall (WAF) with SQLi rule sets enabled and enforced, not merely logging.
CVE-2020-1472	10.0 Critical	Netlogon privilege escalation (ZeroLogon)	Apply the relevant cumulative security update immediately and enforce secure RPC channel sign/seal.
CVE-2022-21907	9.8 Critical	Windows HTTP.sys remote code execution	Apply the corresponding Windows cumulative update without delay; this is a remotely exploitable, unauthenticated flaw.

CVE	CVSS	Finding	Required Action
CVE-2021-4034	7.8 High	Linux polkit local privilege escalation (PwnKit)	Patch polkit via the distribution package manager; restrict local shell access on this host.
CVE-2014-0160	5.0 Medium	OpenSSL Heartbleed information disclosure	Upgrade OpenSSL and reissue any TLS certificates/keys that may have been exposed on this host historically.

This host alone carried a Critical SQL injection vulnerability that gave the attacker direct entry, plus two additional unrelated Critical-severity vulnerabilities that were not used in this attack but represent equally serious, independent avenues of compromise. Patching the SQL injection flaw alone is not sufficient; this host requires a full remediation pass against all five findings above.

Environment-Wide Vulnerability Remediation

Beyond the entry-point host, the pre-incident Nessus scan identified significant, largely unpatched vulnerabilities across the remaining nine scanned hosts, several scoring above the entry point itself in calculated risk. These represent latent risk that, left unaddressed, could enable a similar or more severe incident even after the specific issues used in this attack are fixed.

Host	Calculated Risk Score (0-100)
10.10.4.156	99.3
10.10.3.233	98.6
10.10.6.61	97.2
10.10.4.11	95.3

Host	Calculated Risk Score (0-100)
10.10.3.147	94.6
10.10.1.45 (Entry Point)	92.5
10.10.8.235	91.3
10.10.7.158	84.0
10.10.2.165	80.7
10.10.1.25	79.2

Notable Critical findings on the highest-risk hosts include:

- 10.10.4.156 (risk 99.3): Netlogon/Zerologon (CVSS 10.0) and Windows HTTP.sys RCE (CVSS 9.8), both remotely exploitable, unauthenticated.
- 10.10.3.233 (risk 98.6): Spring Framework RCE / Spring4Shell (CVSS 9.8) and F5 BIG-IP iControl REST authentication bypass (CVSS 9.8).
- 10.10.6.61 (risk 97.2): F5 BIG-IP TMUI RCE (CVSS 10.0), F5 iControl REST bypass (CVSS 9.8), and Apache mod_proxy SSRF (CVSS 9.0) — three independent Critical findings on a single host.
- 10.10.3.147 (risk 94.6): Apache Log4j RCE / Log4Shell (CVSS 10.0), Netlogon/Zerologon (CVSS

10.0), and Apache Struts RCE (CVSS 9.8).

- 10.10.8.235 (risk 91.3): Apache Struts Jakarta Multipart Parser RCE, the same vulnerability class implicated in the 2017 Equifax breach (CVSS 10.0), and Microsoft Exchange ProxyLogon SSRF (CVSS 9.8). The full findings list, including every CVE, CVSS score, and affected host, is provided in Appendix A for the technical remediation team.

Detection and Monitoring Improvements

- Alert on repeated HTTP 401 responses from a single source IP against the login endpoint, and on user-agent strings associated with known automated attack tooling.
- Correlate web-application compromise indicators with subsequent authentication activity from internal service accounts within a short time window, to catch the SQLi-to lateral-movement pattern seen in this incident before it reaches the transaction tier.
- Alert whenever a service account performs an interactive or network logon outside its documented, expected behaviour pattern.
- Monitor for process creation events launching scripting interpreters (Python, PowerShell, cmd.exe) on transaction-processing servers, and require change management approval for any legitimate instance.
- Implement transaction-level anomaly detection for transfers initiated by service accounts rather than named human users, with a mandatory hold for manual review above a defined value threshold.

Conclusion:

This incident followed a well-understood pattern: a known, previously-identified web application vulnerability provided initial access; inadequate network segmentation allowed the attacker to reach systems far more sensitive than the entry point warranted; and the absence of transaction-level anomaly detection allowed five fraudulent transfers to complete before the bank's overnight fraud-detection system raised an alert. Every stage of this attack chain maps to a specific, addressable gap identified in this report.

FirstBank Nigeria's regulatory obligations under the CBN Risk-Based Cybersecurity Framework, BOFIA 2020, and the NDPA 2023 are time-critical and should be treated as running in parallel with, not after, the technical remediation work in Section 4. The Executive Committee is asked to approve the immediate actions in Section 4.1 without delay, and to assign named owners to each regulatory deadline in Section 3.

Appendix A: Complete Nessus Vulnerability Findings Full list of vulnerabilities identified in the pre-incident Nessus scan, by host, in descending order of calculated host risk score.

Host	CVE	CVSS	Risk	Port	Finding
10.10.4.156	CVE-2020-1472	10.0	Critical	135	Netlogon Privilege Escalation (ZeroLogon)
10.10.4.156	CVE-2022-21907	9.8	Critical	80	Windows HTTP.sys Remote Code Execution
10.10.3.233	CVE-2022-22965	9.8	Critical	8080	Spring Framework RCE (Spring4Shell)
10.10.3.233	CVE-2022-1388	9.8	Critical	443	F5 BIG-IP iControl REST Authentication Bypass
10.10.6.61	CVE-2020-5902	10.0	Critical	443	F5 BIG-IP TMUI Remote Code Execution
10.10.6.61	CVE-2022-1388	9.8	Critical	443	F5 BIG-IP iControl REST Authentication Bypass
10.10.6.61	CVE-2021-40438	9.0	Critical	80	Apache HTTP Server mod_proxy SSRF
10.10.4.11	CVE-2020-5902	10.0	Critical	443	F5 BIG-IP TMUI Remote Code Execution
10.10.4.11	CVE-2018-11776	9.8	Critical	8080	Apache Struts Remote Code Execution
10.10.4.11	CVE-2022-0847	7.8	High	22	Linux Kernel Dirty Pipe Privilege Escalation
10.10.3.147	CVE-2021-44228	10.0	Critical	8080	Apache Log4j RCE (Log4Shell)
10.10.3.147	CVE-2020-1472	10.0	Critical	135	Netlogon Privilege Escalation (ZeroLogon)
10.10.3.147	CVE-2018-11776	9.8	Critical	8080	Apache Struts Remote Code Execution
10.10.3.147	CVE-2014-0160	5.0	Medium	443	OpenSSL Heartbleed Information Disclosure
10.10.1.45	CVE-2023-23752	9.8	Critical	443	Web Application Login Form SQL Injection
10.10.1.45	CVE-2020-1472	10.0	Critical	135	Netlogon Privilege Escalation (ZeroLogon)
10.10.1.45	CVE-2022-21907	9.8	Critical	80	Windows HTTP.sys Remote Code Execution
10.10.1.45	CVE-2021-4034	7.8	High	22	Linux polkit Privilege Escalation (PwnKit)
10.10.1.45	CVE-2014-0160	5.0	Medium	443	OpenSSL Heartbleed Information Disclosure
10.10.8.235	CVE-2017-5638	10.0	Critical	80	Apache Struts Jakarta Multipart Parser

Host	CVE	CVSS	Risk	Port	Finding
					RCE
10.10.8.235	CVE-2021-26855	9.8	Critical	443	Microsoft Exchange SSRF (ProxyLogon)
10.10.8.235	CVE-2023-44487	7.5	High	443	HTTP/2 Rapid Reset Denial of Service
10.10.8.235	CVE-2023-0386	7.0	High	22	Linux Kernel OverlayFS Privilege Escalation
10.10.7.158	CVE-2021-40438	9.0	Critical	80	Apache HTTP Server mod_proxy SSRF
10.10.2.165	CVE-2020-5902	10.0	Critical	443	F5 BIG-IP TMUI Remote Code Execution
10.10.2.165	CVE-2021-34527	8.8	High	445	Windows Print Spooler RCE (PrintNightmare)
10.10.2.165	CVE-2022-0847	7.8	High	22	Linux Kernel Dirty Pipe Privilege Escalation
10.10.2.165	CVE-2023-0386	7.0	High	22	Linux Kernel OverlayFS Privilege Escalation
10.10.1.25	CVE-2014-6271	10.0	Critical	80	GNU Bash RCE (Shellshock)
10.10.1.25	CVE-2021-34527	8.8	High	445	Windows Print Spooler RCE (PrintNightmare)
10.10.1.25	CVE-2021-4034	7.8	High	22	Linux polkit Privilege Escalation (PwnKit)
10.10.1.25	CVE-2014-0160	5.0	Medium	443	OpenSSL Heartbleed Information Disclosure

Appendix B: Confirmed Attack Timeline

Timestamp	Event
20 Feb 2026, 22:08:09 – 22:13:15 UTC	Repeated automated login attempts against the login endpoint from 45.195.195.51, using the sqlmap automated SQL injection tool.
20 Feb 2026, 22:21:00 UTC	SQL injection payload submitted via the login form.
20 Feb 2026, 22:21:45 UTC	First successful (HTTP 200) authenticated session established by the attacker.
20 Feb 2026, 22:22:01 – 22:23:07 UTC	Attacker accesses administrative account-listing, user-listing, and export functions.
20 Feb 2026, 23:25:34 UTC	Explicit-credential logon recorded for the svc_report service account (EventCode 4648) on the web server.
20 Feb 2026, 23:28:23 UTC	Network logon (EventCode 4624, LogonType 3) from 10.10.1.45 to the transaction server — confirmed lateral movement.
20 Feb 2026, 23:32:01 – 23:32:09 UTC	Process creation events (EventCode 4688) on the transaction server: cmd.exe followed by python.exe executing the transfer script.
20 Feb 2026, 23:41:52 UTC	First fraudulent wire transfer executed.
21 Feb 2026, 00:31:36 UTC	Fifth and final fraudulent wire transfer executed. Total value moved: NGN 13,094,903.00.

also,The investigation successfully reconstructed the simulated FirstBank SOC incident from the supplied evidence. The attacker originated from 45.195.195.51 and used sqlmap/1.7.8 against the banking login endpoint. Successful access was followed by compromise and use of the svc_report service account, privilege assignment and movement from WEBSVR01 to TXNSVR04. On the transaction server, EventCode 4688 captured execution of a Python-based transfer automation, and the banking transaction log identified five fraudulent transfers totaling NGN 13,094,902.94.

The strongest aspect of the investigation is the cross-source correlation. No single log source provides the whole story; the web log explains initial access, Windows logs explain internal activity, and the transaction log establishes business impact. Together, these sources create a defensible attack timeline.

Evidence appendix

401	/login	sqlmap/1.7.8stable (https://
401	/login	sqlmap/1.7.8stable (https://
401	/login	sqlmap/1.7.8stable (https://
401	/login	sqlmap/1.7.8stable (https://
401	/login	sqlmap/1.7.8stable (https://
200	/login?username=%27+OR+%27%3D%27%3D%27+---&password=x	sqlmap/1.7.8stable (https://
200	/login	sqlmap/1.7.8stable (https://

Additional web-access evidence captured during the investigation.

109 events before 8/1/25 4:43:50.000 PM

No Event Sampling

Job

Smart Mode

EventsPatternsStatistics (109)Visualization

20 Per PageFormatPreview

Page123456Next

Time	EventCode	AccountName	SourceIP	WorkstationName	TargetServerName
2025-02-28 08:08:08	4024	chidi memo	10.10.4.26	WS17-014	WS17-014
2025-02-28 08:04:25	4024	adebi akafar	10.10.4.25	WS17-009	WS17-009
2025-02-28 08:13:32	4024	awaka oke	10.10.3.39	WS17-019	WS17-019
2025-02-28 08:21:55	4024	adebi akafar	10.10.4.13	WS17-020	WS17-020
2025-02-28 08:24:46	4024	rguzi ibrahim	10.10.2.58	WS17-007	WS17-007
2025-02-28 08:30:59	4024	awaka oke	10.10.3.59	WS17-001	WS17-001
2025-02-28 08:30:17	4024	tunde afolabi	10.10.5.99	WS17-027	WS17-027
2025-02-28 08:41:04	4024	awaka oke	10.10.3.68	WS17-027	WS17-027
2025-02-28 08:45:27	4024	adebi akafar	10.10.2.44	WS17-030	WS17-030
2025-02-28 08:51:34	4024	segun bello	10.10.2.69	WS17-016	WS17-016
2025-02-28 08:58:08	4024	tunde afolabi	10.10.3.21	WS17-005	WS17-005
2025-02-28 09:05:17	4024	awaka oke	10.10.4.47	WS17-019	WS17-019
2025-02-28 09:07:09	4024	segun bello	10.10.1.54	WS17-014	WS17-014
2025-02-28 09:10:04	4024	rguzi ibrahim	10.10.4.72	WS17-024	WS17-024
2025-02-28 09:16:58	4024	ifeyemi mbaaka	10.10.2.88	WS17-019	WS17-019
2025-02-28 09:20:15	4024	tunde afolabi	10.10.2.53	WS17-017	WS17-017
2025-02-28 09:25:26	4024	chidi memo	10.10.2.74	WS17-011	WS17-011
2025-02-28 09:29:55	4024	rguzi ibrahim	10.10.4.92	WS17-022	WS17-022
2025-02-28 09:37:08	4024	tunde afolabi	10.10.2.70	WS17-011	WS17-011
2025-02-28 09:41:28	4024	awaka oke	10.10.3.54	WS17-004	WS17-004

Additional Windows authentication context captured during the investigation.

SUMMARY

Attacker IP : 45.195.195.51

Entry Point : 10.10.1.45 / WEBSVR01

Initial access was achieved through SQL injection against the public-facing login endpoint.

The attacker then abused svc_report, moved to TXNSVR04, executed a Python transfer script, and caused five fraudulent transfers totaling NGN 13,094,903.00.

ATTACK TIMELINE

2026-02-20 22:08:09+ Repeated HTTP 401 login attempts from 45.195.195.51 using sqlmap/1.7.8
2026-02-20 23:21:38+ Successful HTTP 200 login; initial web compromise established
2026-02-20 23:25:34+ svc_report explicit-credential activity (EventCode 4648)
2026-02-20 23:25:37+ svc_report receives special privileges (EventCode 4672)
2026-02-20 23:28:23+ Successful network logon to TXNSVR04 (EventCode 4624)
2026-02-20 23:28:38+ Network-share access on TXNSVR04 (EventCode 5140)
2026-02-20 23:32:01+ cmd.exe created under svc_report (EventCode 4688)
2026-02-20 23:32:09+ Python executes C:\Scripts\bulk_transfer.py with
overnight_batch_20260220.csv
2026-02-20 23:41:52+ TXN-1064 — NGN 3,037,380.99
2026-02-20 23:59:43+ TXN-1065 — NGN 954,481.26
2026-02-21 00:18:53+ TXN-1066 — NGN 4,563,224.77
2026-02-21 00:24:37+ TXN-1067 — NGN 3,591,357.21
2026-02-21 00:31:36+ TXN-1068 — NGN 948,458.77

AFFECTED HOSTS AND RISK SCORES

10.10.4.156 score=99.3
10.10.3.233 score=98.6
10.10.6.61 score=97.2
10.10.4.11 score=95.3
10.10.3.147 score=94.6
10.10.1.45 score=92.5
10.10.8.235 score=91.3
10.10.7.158 score=84.0
10.10.2.165 score=80.7
10.10.1.25 score=79.2

COMPROMISED ACCOUNTS

NG76183305
NG98016294
NG92252632
NG35171490
NG77374324

CONFIRMED COMPROMISE HOSTS

10.10.1.45
10.10.9.20

RECOMMENDATIONS

1. Immediately disable and rotate svc_report and review its access.
2. Patch the SQL injection vulnerability on the public-facing login service.
3. Isolate WEBSVR01 and TXNSVR04 and preserve forensic evidence.
4. Recover or freeze the five fraudulent transfers where operationally and legally appropriate.
5. Segment the public web tier from the transaction-processing tier using default-deny controls.
6. Deploy WAF SQL-injection protection and service-account anomaly detection.
7. Patch the broader Critical vulnerability backlog identified by Nessus.
8. Complete applicable CBN, BOFIA, NDPA and PCI DSS incident-response actions.

THANK YOU